

FakeBank Web Enumeration & Exploitation using Gobuster (TryHackMe)

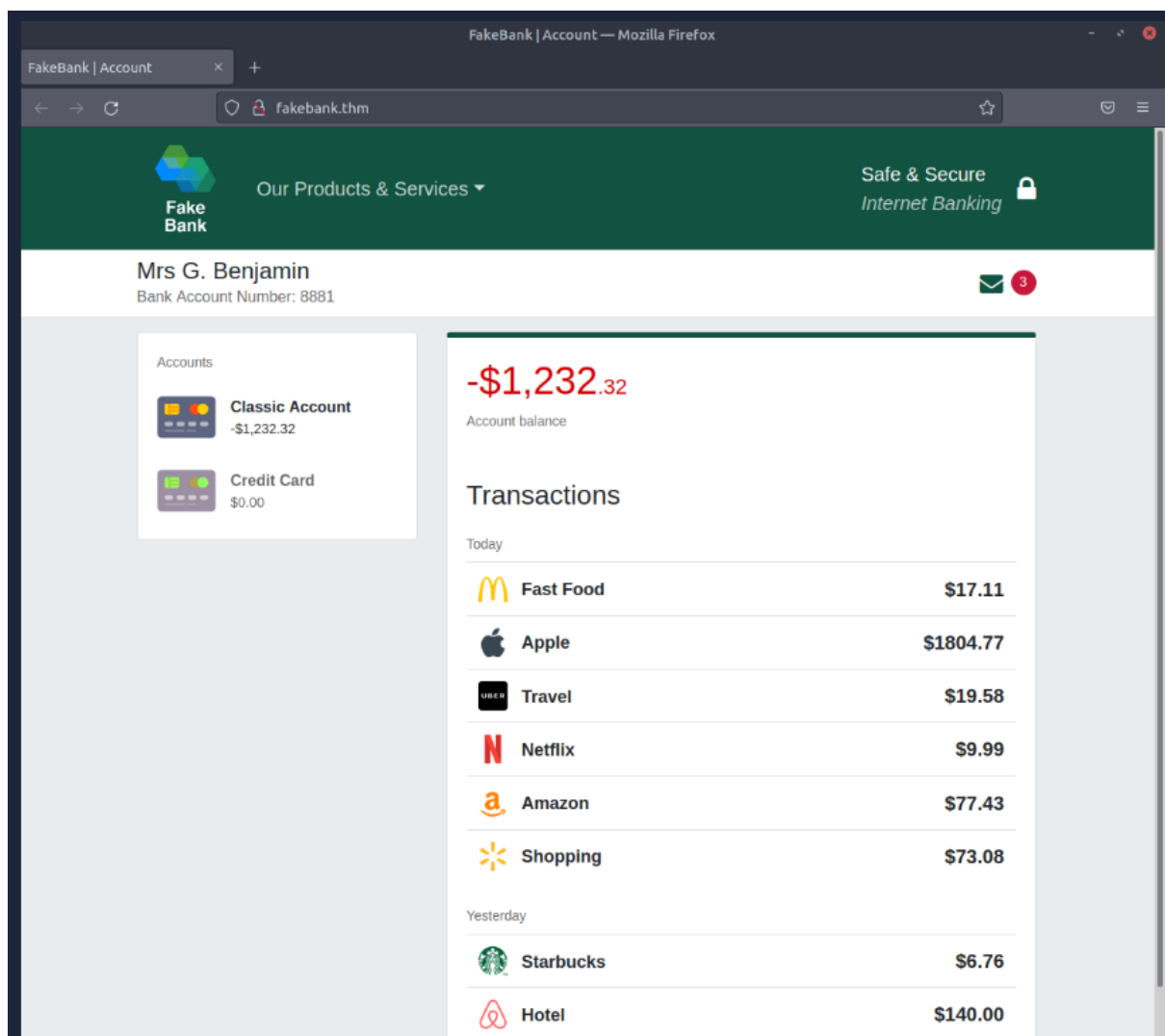
Objective

The goal of this lab is to perform **web directory enumeration** to discover hidden endpoints and exploit insecure functionality in a banking application.

Tools Used

- Gobuster
- Web Browser
- Linux Terminal

Start the machine



Note: Gobuster is a free and open-source directory and file enumeration tool. Penetration testers and security professionals use it to find hidden directories and files on web servers.

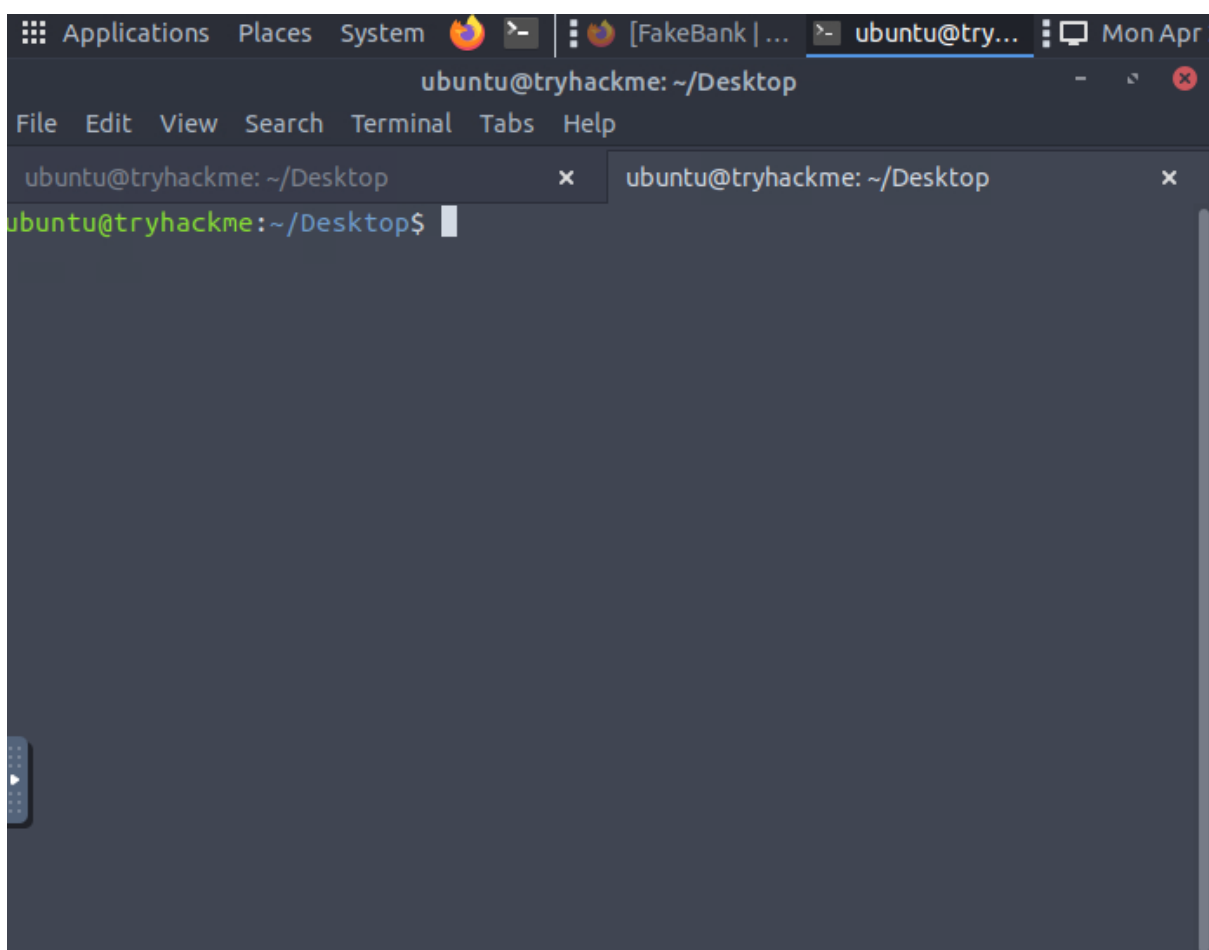
Directory brute forcing is a technique used in web security to **discover hidden files and folders on a website** by automatically trying many possible names.

Your First Hack

We will use a command-line application called "[Gobuster\(opens in new tab\)](#)" to brute-force FakeBank's website to find hidden directories and pages. Gobuster will take a list of potential page or directory names and try accessing a website with each of them; if the page exists, it tells you.

Step 1. Open A Terminal

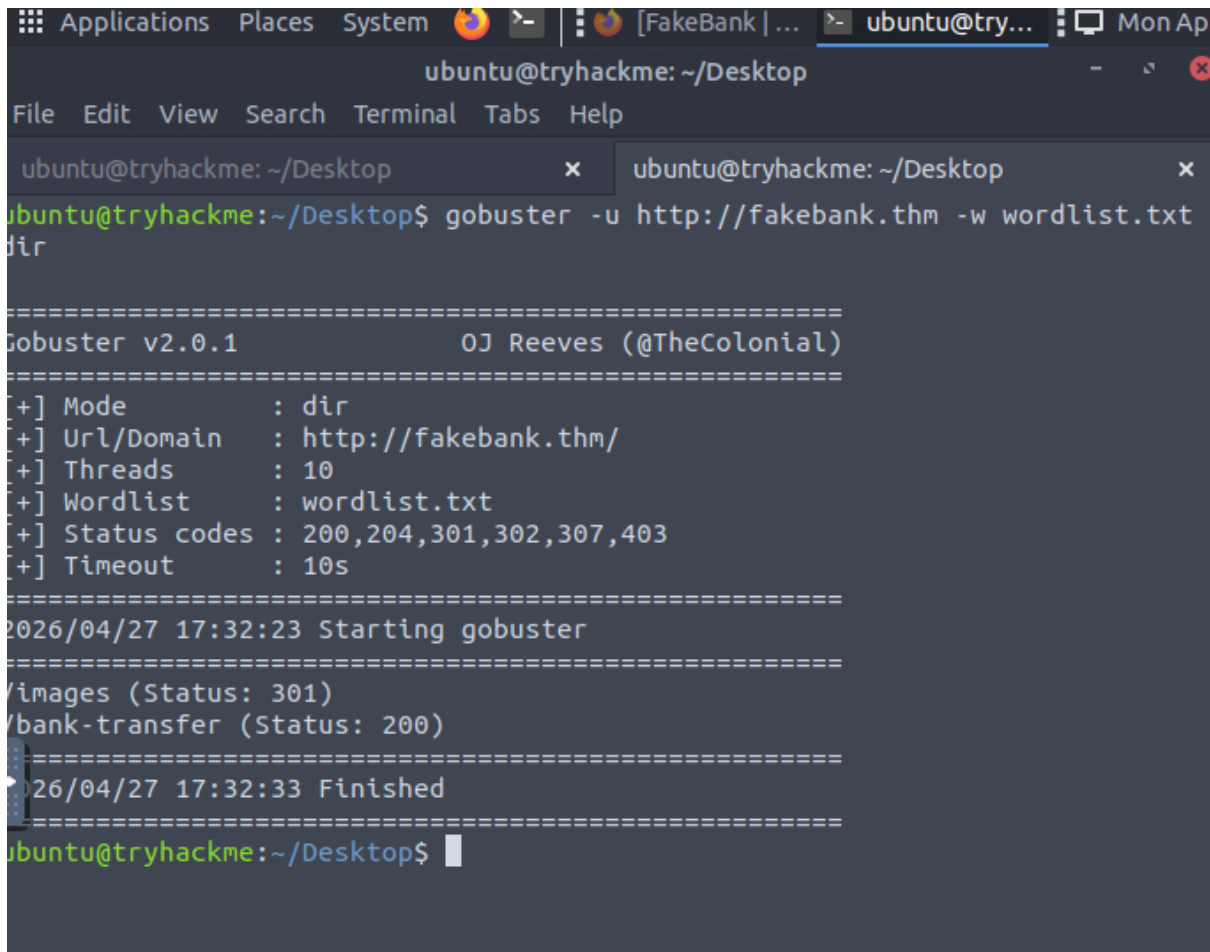
A terminal, also known as the command line, allows us to interact with a computer without using a graphical user interface. On the machine, open the terminal by clicking on the Terminal icon on the right of the screen.



Step 2. Use Gobuster To Find Hidden Website Pages

Most companies have an admin portal page, giving their staff access to basic admin controls for day-to-day operations. For a bank, an employee might need to transfer money to and from client accounts. Due to human error or negligence, there may be instances when these pages are not made private, allowing attackers to find hidden pages that show or give access to admin controls or sensitive data.

To begin, type the following command into the terminal to find potentially hidden pages on FakeBank's website using Gobuster (a command-line security application).



```
Applications Places System [FakeBank | ... ubuntu@tryhackme: ~/Desktop
ubuntu@tryhackme: ~/Desktop
File Edit View Search Terminal Tabs Help
ubuntu@tryhackme: ~/Desktop x ubuntu@tryhackme: ~/Desktop x
ubuntu@tryhackme:~/Desktop$ gobuster -u http://fakebank.thm -w wordlist.txt dir
=====
Gobuster v2.0.1 OJ Reeves (@TheColonial)
=====
[+] Mode : dir
[+] Url/Domain : http://fakebank.thm/
[+] Threads : 10
[+] Wordlist : wordlist.txt
[+] Status codes : 200,204,301,302,307,403
[+] Timeout : 10s
=====
2026/04/27 17:32:23 Starting gobuster
=====
/images (Status: 301)
/bank-transfer (Status: 200)
=====
2026/04/27 17:32:33 Finished
=====
ubuntu@tryhackme:~/Desktop$
```

In the command above, -u is used to state the website we're scanning, -w takes a list of words to iterate through to find hidden pages.

You will see that Gobuster scans the website with each word in the list, finding pages that exist on the site. Gobuster will have told you the pages in the list of page/directory names (indicated by Status: 200).

More detail : -u = **URL**

Target website you are testing

-w = **wordlist**

This is a file containing **common directory names**

dir = **directory brute-forcing mode**

It tells Gobuster:

“Find hidden folders/files on this website”

What happens when you run it?

Gobuster will:

1. Take each word from wordlist.txt
2. Attach it to the URL
3. Send requests like:

http://fakebank.thm/admin

http://fakebank.thm/login

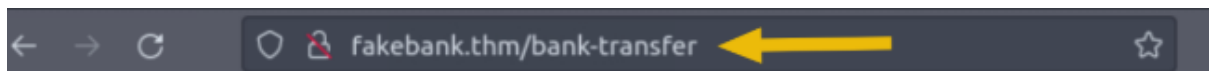
4. Check responses (200, 403, etc.)
5. Show valid results



/bank-transfer (status: 200) so now use the url

Step 3. Hack The Bank

You should have found a secret bank transfer page that allows you to transfer money between bank accounts (/bank-transfer). Type the hidden page into the FakeBank website using the browser's address bar



From this page, an attacker has authorized access and can steal money from any bank account. As an ethical hacker, you would (with permission) find vulnerabilities in their application and report them to the bank to fix them before a hacker exploits them.

FakeBank | Bank Transfer — Mozilla Firefox

Restore Session × FakeBank | Bank Transfer × +

← → ↻ fakebank.thm/bank-transfer ☆

 Fake Bank 

Staff Account 
Transfer money between accounts

Admin Portal

Send from

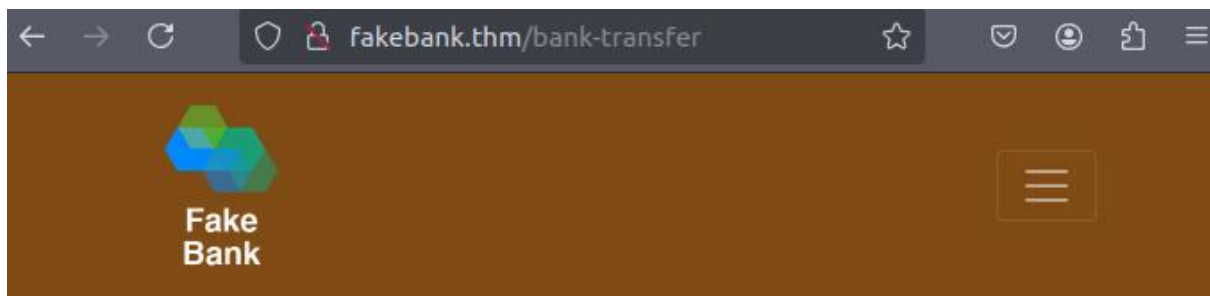
Send to

Amount to send in USD

Send Money

Your mission is to transfer \$2000 from bank account 2276 to your account (account number 8881). If your transfer was successful, you should now be able to see your new balance reflected on your account page.

Go there now and confirm you got the money! (You may need to hit Refresh for the changes to appear)



Staff Account

Transfer money between accounts



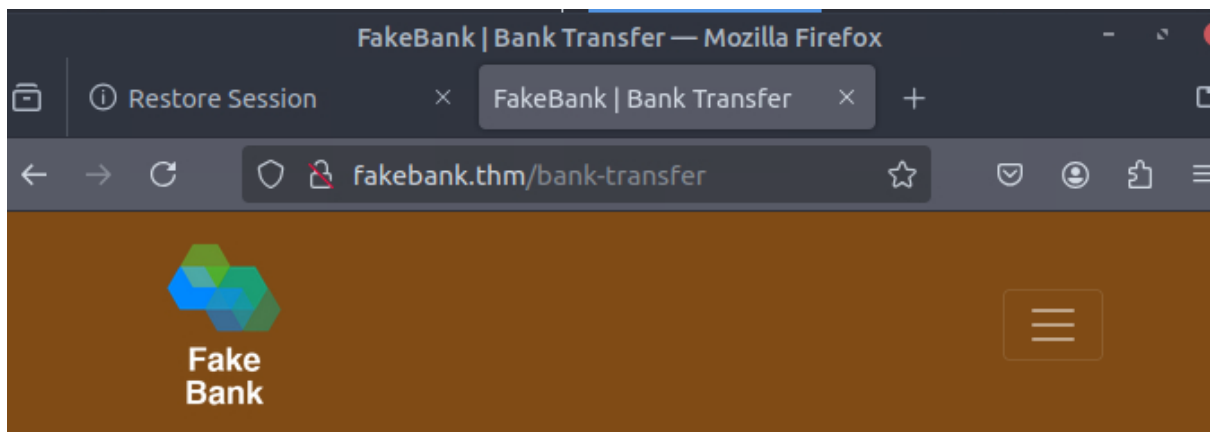
Admin Portal

Send from

Send to

Amount to send in USD

Send Money



Staff Account

Transfer money between accounts



Success, transfer completed

You have successfully completed the transfer, here are the details for reference:

Transfer reference:

123

Amount:

2000 USD

Date of transfer:

2026-04-27

[Return to Your Account](#)



Congratulations - you hacked the bank!
The answer to the TryHackMe question is
BANK-HACKED

Vulnerability Summary

- Broken Access Control
- Sensitive endpoint exposed
- No authentication/authorization

Remediation

- Implement authentication for admin pages
- Restrict access using role-based controls
- Hide sensitive endpoints from public access

What I Learned

- How to use Gobuster for directory brute-forcing
- Importance of endpoint security
- Real-world example of Broken Access Control

Conclusion

- This lab demonstrates how attackers can exploit poorly secured web applications using simple enumeration techniques.